

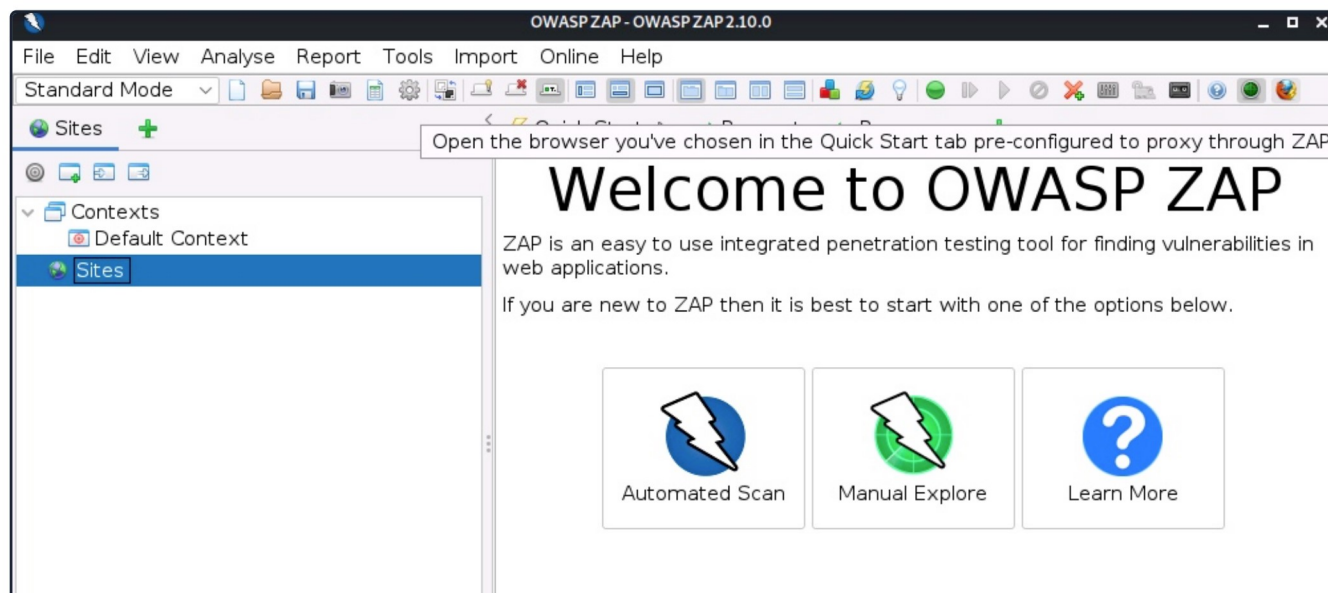
Crawling

Crawling a website is the systematic or automatic process of exploring a website to list all of the resources encountered along the way. It shows us the structure of the website we are auditing and an overview of the attack surface we will be testing in the future. We use the crawling process to find as many pages and subdirectories belonging to a website as possible.

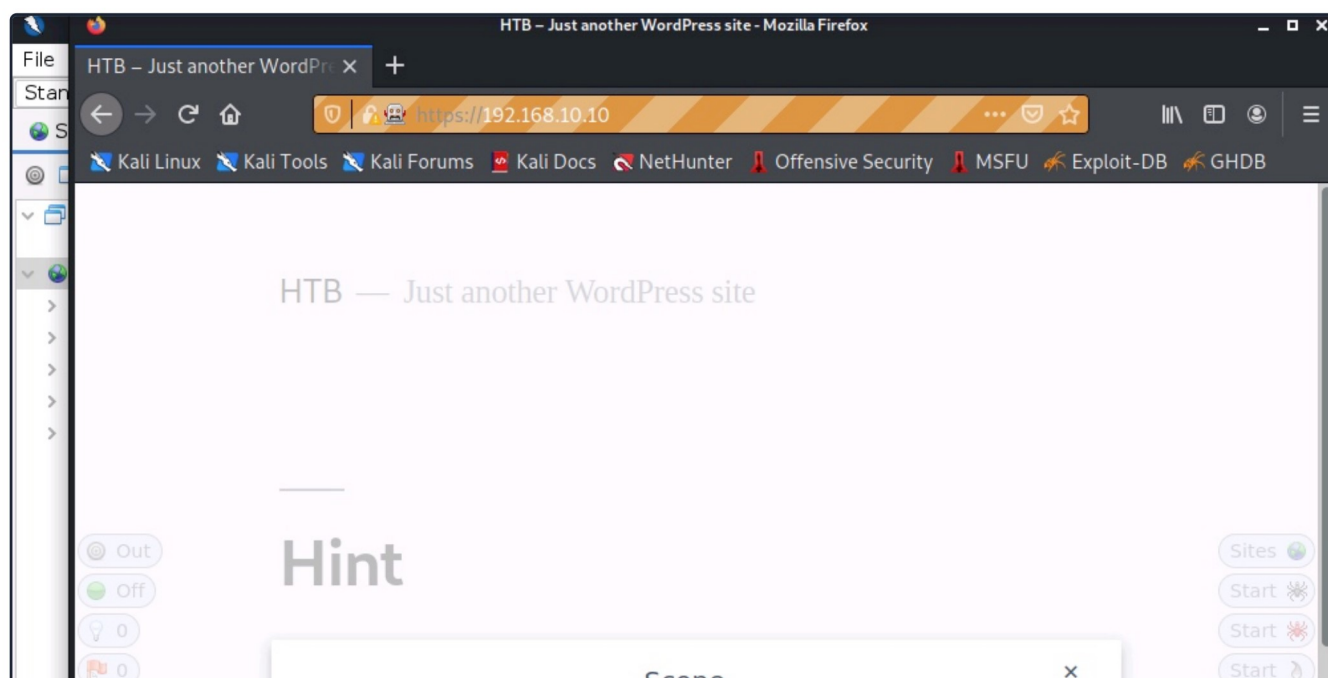
ZAP

[Zed Attack Proxy \(ZAP\)](#) is an open-source web proxy that belongs to the [Open Web Application Security Project \(OWASP\)](#). It allows us to perform manual and automated security testing on web applications. Using it as a proxy server will enable us to intercept and manipulate all the traffic that passes through it.

We can use the spidering functionality following the next steps. Open ZAP, and on the top-right corner, open the browser.

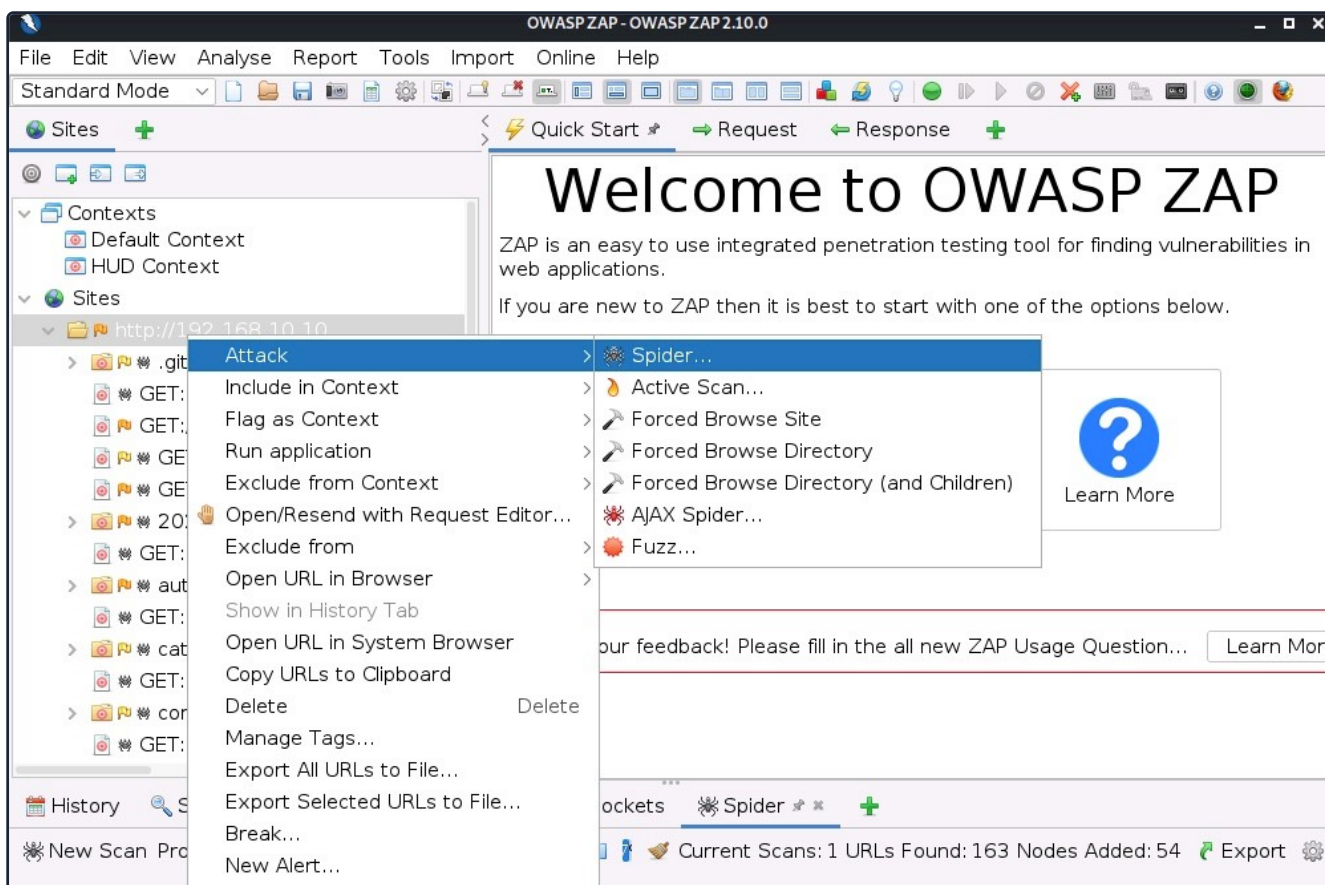


Write the website in the address bar and add it to the scope using the first entry in the left menu.

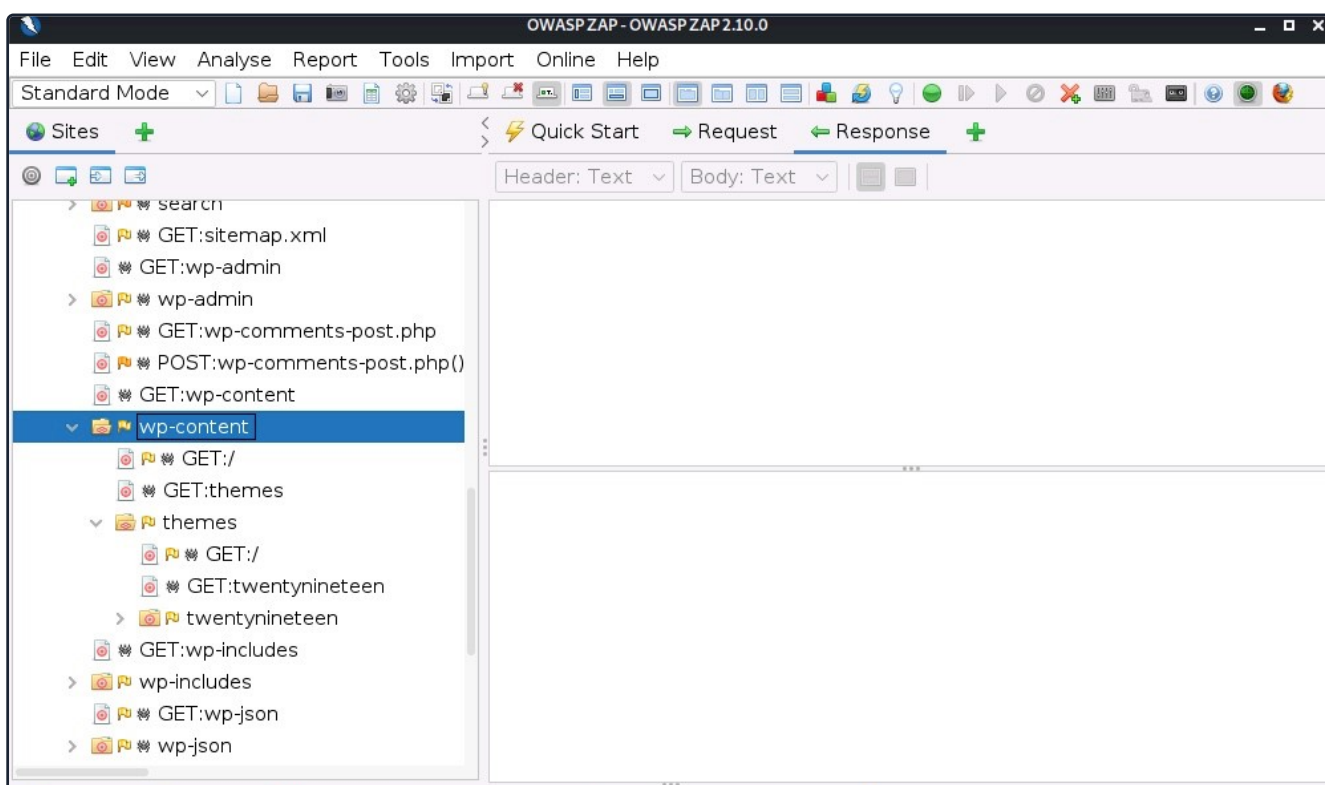




Head back to the ZAP Window, right-click on the target website, click on the Attack menu, and then the Spider submenu.

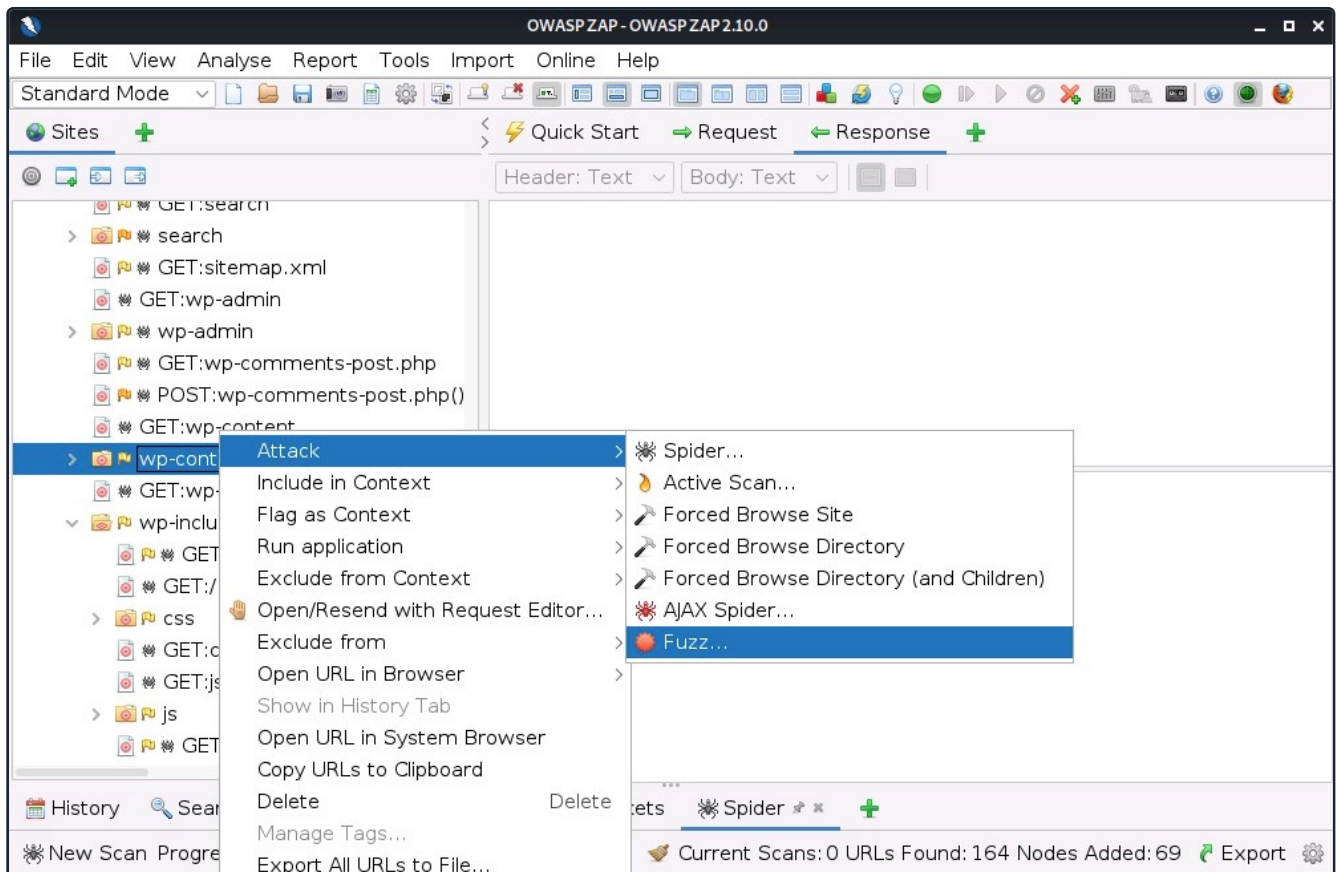
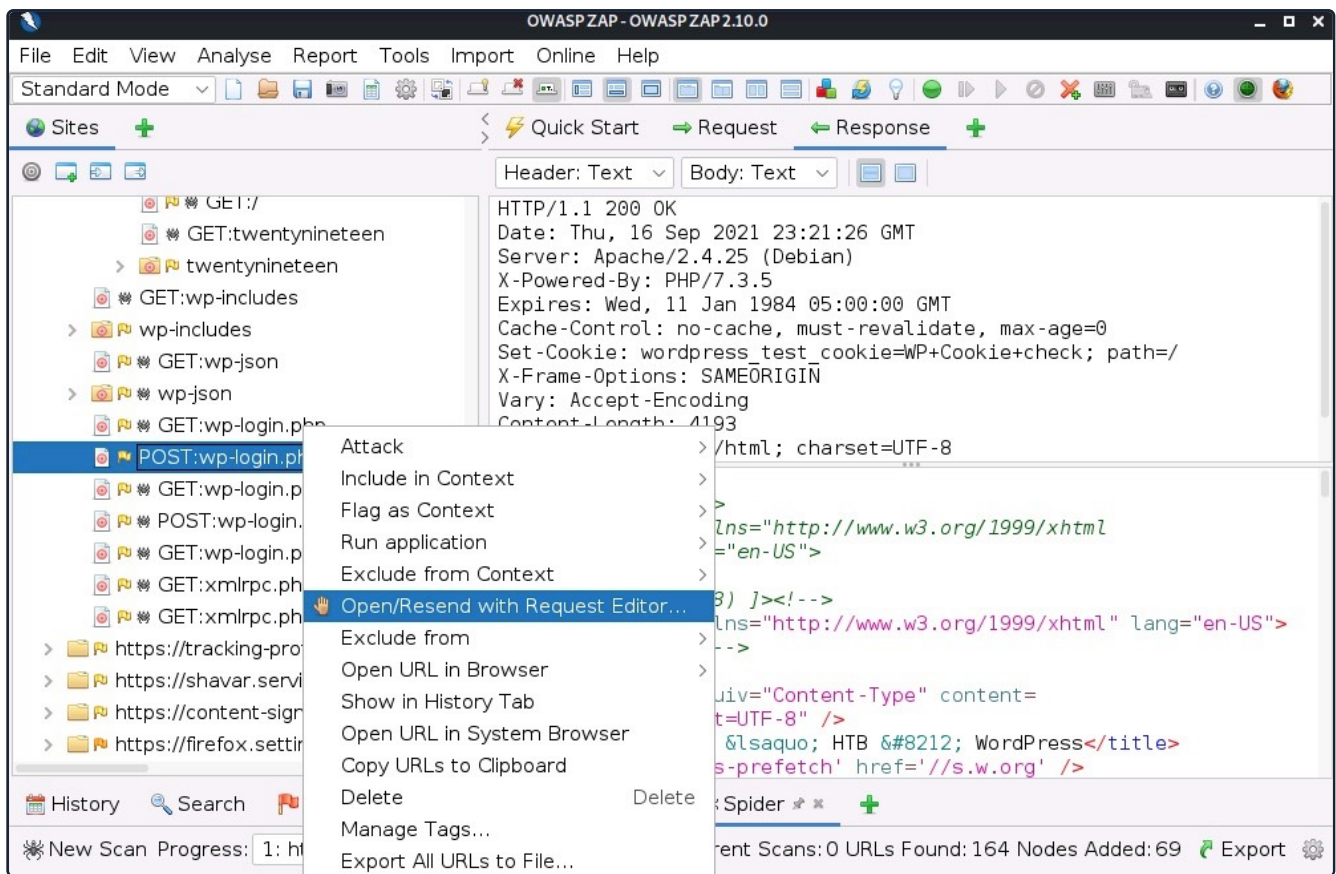


Once the process has finished, we can see the resources discovered by the spidering process.





One handy feature of ZAP is the built-in Fuzzer and Manual Request Editor. We can send any request to them to alter it manually or fuzz it with a list of payloads by right-clicking on the request and using the menu "Open/Resend with Request Editor..." or the "Fuzz..." submenu under the Attack menu.



ZAP has excellent [documentation](#) that can help you to get used to it quickly. For a more detailed study on ZAP, check out the [Using Web Proxies module](#) on HTB Academy.

FFuF

ZAP spidering module only enumerates the resources it finds in links and forms, but it can miss important information such as hidden folders or backup files.

We can use `ffuf` to discover files and folders that we cannot spot by simply browsing the website. All we need to do is launch `ffuf` with a list of folders names and instruct it to look recursively through them.

```
dbcypth0n@htb[/htb]$ ffuf -recursion -recursion-depth 1 -u http://192.168.10.10/FUZZ -w /opt/useful/SecLists/Di
```

```
/'___\ /'___\ /'___\
/\ \_/\ /\ \_/\ _ _ _\ /\ \_/\
\ \,___\ \ \,___\ \ \ \ \ \,___\
\ \ \_/\ \ \ \_/\ \ \ \ \ \ \_/\
\ \ \_/\ \ \ \_/\ \ \ \_/\ \ \ \_/\
\ \ \_/\ \ \ \_/\ \ \ \_/\ \ \ \_/\
```

v1.1.0-git

```
-----
:: Method      : GET
:: URL         : http://192.168.10.10/FUZZ
:: Wordlist    : FUZZ: /opt/useful/SecLists/Discovery/Web-Content/raft-small-directories-lowercase.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200,204,301,302,307,401,403,405
-----
```

```
wp-admin          [Status: 301, Size: 317, Words: 20, Lines: 10]
[INFO] Adding a new job to the queue: http://192.168.10.10/wp-admin/FUZZ

wp-includes       [Status: 301, Size: 320, Words: 20, Lines: 10]
[INFO] Adding a new job to the queue: http://192.168.10.10/wp-includes/FUZZ

wp-content        [Status: 301, Size: 319, Words: 20, Lines: 10]
[INFO] Adding a new job to the queue: http://192.168.10.10/wp-content/FUZZ

admin             [Status: 302, Size: 0, Words: 1, Lines: 1]
login             [Status: 302, Size: 0, Words: 1, Lines: 1]
feed              [Status: 301, Size: 0, Words: 1, Lines: 1]
[INFO] Adding a new job to the queue: http://192.168.10.10/feed/FUZZ
...
```

- `-recursion`: Activates the recursive scan.
- `-recursion-depth`: Specifies the maximum depth to scan.
- `-u`: Our target URL, and `FUZZ` will be the injection point.
- `-w`: Path to our wordlist.

We can see in the image how `ffuf` creates new jobs for every detected folder. This task can be very resource-intensive for the target server. If the website responds slower than usual, we can lower the rate of requests using the `-rate` parameter.

The module [Attacking Web Applications with Ffuf](#) goes much deeper into `ffuf` usage and showcases many of the techniques taught in this module.

Sensitive Information Disclosure

It is typical for the webserver and the web application to handle the files it needs to function. However, it is common to find backup or unreferenced files that can have important information or credentials. Backup or unreferenced files can be generated by creating snapshots, different versions of a file, or from a text editor without the web developer's knowledge. There are some lists of common extensions we can find in the `raft-[ small | medium | large ]-extensions.txt` files from [SecLists](#).

We will combine some of the folders we have found before, a list of common extensions, and some words extracted from the website to see if we can find something that should not be there. The first step will be to create a file with the following folder names and save it as `folders.txt`.

```
wp-admin
wp-content
wp-includes
```

Next, we will extract some keywords from the website using [CeWL](#). We will instruct the tool to extract words with a minimum length of 5 characters `-m5`, convert them to lowercase `--lowercase` and save them into a file called `wordlist.txt` `-w <FILE>`:

```
dbcypth0n@htb[/htb]$ cewl -m5 --lowercase -w wordlist.txt http://192.168.10.10
```

The next step will be to combine everything in `ffuf` to see if we can find some juicy information. For this, we will use the following parameters in `ffuf`:

- `-w`: We separate the wordlists by coma and add an alias to them to inject them as fuzzing points later
- `-u`: Our target URL with the fuzzing points.

```
dbcypth0n@htb[/htb]$ ffuf -w ./folders.txt:FOLDERS,./wordlist.txt:WORDLIST,./extensions.txt:EXTENSIONS -u http://192.168.10.10/FOLDERS/WORDLISTEXTENSIONS
```

```
/'_--\ /'_--\ /'_--\
/\ \_/\ /\ \_/\  _ _  /\ \_/\
\ \ ,_ \ \ \ ,_ \ \ \ \ \ \ \ ,_ \
\ \ \_/\ \ \ \_/\ \ \ \ \ \ \ \_/\
\ \ \_/\ \ \ \_/\ \ \_/\ \ \ \_/\
\ \_/\ \ \_/\ \ \_/\ \ \_/\
```

v1.1.0-git

```
-----
:: Method      : GET
:: URL         : http://192.168.10.10/FOLDERS/WORDLISTEXTENSIONS
:: Wordlist    : FOLDERS: ./folders.txt
:: Wordlist    : WORDLIST: ./wordlist.txt
:: Wordlist    : EXTENSIONS: ./extensions.txt
:: Follow redirects : false
:: Calibration   : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,204,301,302,307,401,403,405
-----
```

[Status: 200, Size: 8, Words: 1, Lines: 2]

```
* EXTENSIONS: ~
* FOLDERS: wp-content
* WORDLIST: wp-content
```

```
* WORDLIST: secret

[Status: 200, Size: 0, Words: 1, Lines: 1]
* FOLDERS: wp-includes
* WORDLIST: comment
* EXTENSIONS: .php

[Status: 302, Size: 0, Words: 1, Lines: 1]
* FOLDERS: wp-admin
* WORDLIST: comment
* EXTENSIONS: .php

...
```

```
dbcypth0n@htb[/htb]$ curl http://192.168.10.10/wp-content/secret~
0ooops!
```

Following this approach, we have successfully found a secret file.

[< Previous](#)
[Next >](#)
[✔ Mark Complete & Next](#)
[📄 Cheat Sheet](#)

Table of Contents

Information Gathering



Passive Information Gathering

📁 WHOIS



📁 DNS



Passive Subdomain Enumeration



Passive Infrastructure Identification



Active Information Gathering

📁 Active Infrastructure Identification



📁 Active Subdomain Enumeration

📁 Virtual Hosts



[Crawling](#)

Putting it all Together

📁 Information Gathering - Web - Skills Assessment

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left